

Laboratório Prático — Governance, Risk & Compliance (GRC) em Cibersegurança

Projeto GRC TechRetail Solutions

Laboratório de Governança, Gestão de Riscos e Conformidade para Empresa Fictícia

Cenário

Fui contratado como analista de GRC para auxiliar a empresa fictícia **TechRetail Solutions**, uma empresa de e-commerce que armazena dados de clientes, realiza pagamentos online e utiliza serviços em nuvem.

A empresa cresceu rapidamente, porém ainda não possui:

- Políticas formais de segurança
- Processo estruturado de gestão de riscos
- Inventário adequado de ativos
- Controles documentados
- Adequação parcial à LGPD
- Processo de conformidade com frameworks internacionais

Meu objetivo foi realizar uma avaliação completa de Governança, Risk & Compliance (GRC), identificando riscos, analisando conformidade e propondo melhorias de segurança alinhadas às melhores práticas do mercado.

Objetivos do Laboratório

Durante este laboratório, realizei atividades relacionadas a:

- ✓ Governança de Segurança da Informação
- ✓ Gestão de Riscos Cibernéticos
- ✓ Avaliação de Controles de Segurança
- ✓ Conformidade com normas e frameworks
- ✓ Criação de documentação organizacional
- ✓ Apoio à tomada de decisão baseada em risco

Etapas do Laboratório

Inventário de Ativos

Realizei o levantamento dos principais ativos críticos da empresa:

Ativo	Tipo	Criticidade
Servidor Web	Infraestrutura	Alta
Banco de Dados de Clientes	Dados Sensíveis	Crítica
Microsoft 365	SaaS	Alta
Firewall	Segurança	Alta
Estações de Trabalho	Endpoint	Média
Sistema ERP	Aplicação	Alta

Ferramentas utilizadas

- Excel / Google Sheets
- Planilha de Inventário

Identificação de Ameaças e Vulnerabilidades

Analisei possíveis ameaças que poderiam impactar os ativos da organização:

Ameaça	Vulnerabilidade
Phishing	Falta de treinamento
Ransomware	Backups insuficientes
Vazamento de Dados	Controle de acesso fraco
Exploração de Vulnerabilidades	Sistemas desatualizados
Acesso Não Autorizado	MFA não implementado

Framework de apoio

- MITRE ATT&CK

Avaliação de Riscos

Realizei a análise de impacto e probabilidade para construção da matriz de riscos.

Exemplo de Matriz de Risco

Risco	Impacto	Probabilidade	Nível
Vazamento de dados	Alto	Alto	Crítico
Ransomware	Alto	Médio	Alto
Phishing	Médio	Alto	Alto
Falha de Backup	Alto	Médio	Alto
Indisponibilidade do ERP	Médio	Médio	Moderado

Tratamento dos riscos

- Mitigar
- Aceitar
- Transferir
- Evitar

Avaliação de Controles de Segurança

Analisei controles técnicos e administrativos existentes:

Controle	Status
MFA	Parcial
Backup	Insuficiente
Antivírus	Implementado
Firewall	Implementado
Política de Senhas	Fraca
Controle de Acesso	Parcial

Frameworks utilizados

- CIS Controls
- NIST Cybersecurity Framework

Análise de Conformidade (Compliance)

Realizei uma análise de aderência da empresa aos principais frameworks e normas.

Frameworks Avaliados

- ISO/IEC 27001
- NIST Risk Management Framework
- Lei Geral de Proteção de Dados

Gaps identificados

Requisito	Status
Política de Segurança	Não Implementada
Gestão de Incidentes	Parcial
Controle de Acesso	Parcial
Gestão de Riscos	Não Formalizada
Backup e Recuperação	Insuficiente
Conscientização de Usuários	Ausente

Criação de Políticas de Segurança

Desenvolvi documentos organizacionais como:

- Política de Segurança da Informação
- Política de Controle de Acesso
- Política de Backup
- Política de Senhas
- Política de Gestão de Incidentes

Plano de Mitigação

Criei recomendações priorizadas para redução de riscos:

Ação	Prioridade
Implementar MFA	Alta
Melhorar backups	Alta
Atualizar sistemas	Alta
Treinamento contra phishing	Média
Revisão de acessos	Média
Formalizar políticas	Alta

Resultados Obtidos

Durante este laboratório consegui desenvolver experiência prática em:

- ✓ Governança de Segurança da Informação
- ✓ Gestão e classificação de riscos
- ✓ Construção de matriz de riscos
- ✓ Avaliação de conformidade
- ✓ Análise de gaps de segurança
- ✓ Estruturação de controles organizacionais
- ✓ Criação de documentação técnica
- ✓ Interpretação de frameworks internacionais
- ✓ Apoio à tomada de decisão baseada em risco

Habilidades Desenvolvidas

- Risk Assessment
- Risk Analysis
- Compliance Assessment
- Security Governance
- Security Controls Review
- Gap Analysis

- Documentação Técnica
- Gestão de Riscos Cibernéticos
- Conformidade com LGPD
- Aplicação de Frameworks de Segurança

Ferramentas Utilizadas

- Microsoft Excel / Google Sheets
- Documentação Técnica
- SIEM para apoio de evidências
- Microsoft Sentinel
- Splunk
- Matriz de Risco
- Frameworks NIST e ISO

Frameworks e Normas Aplicadas

- ISO/IEC 27001
- ISO/IEC 27002
- NIST Cybersecurity Framework
- NIST Risk Management Framework
- CIS Controls
- Lei Geral de Proteção de Dados
- MITRE ATT&CK